SOFTWARE ENGINEERING LABORATORY

LAB 5

STATIC CODE ANALYSIS

Analysis and improvement of a Python To-Do List & Task Manager

Name	Ramalakshmi M N
SRN	PES1UG24AM219
Department	CSE AIML
Experiment	Static analysis using Pylint, Bandit and Flake8

Submitted as part of the Software Engineering Laboratory coursework.

1. Objective

The objective of this experiment was to examine a Python task manager using static code analysis tools, identify coding-style, maintainability and security-related issues, correct the issues, and verify that the program continued to perform its main tasks after the changes.

2. Tools Used

Tool	Purpose
Pylint	Checks Python code for programming errors, code quality concerns, naming conventions, documentation and other maintainability issues.
Bandit	Scans Python source code for common security-related patterns that may require review.
Flake8	Checks Python code for PEP 8 style violations and selected linting issues.

3. Procedure

• The initial version of `todo_manager.py` was reviewed and executed to understand its existing behaviour.

• Pylint, Bandit and Flake8 were run on the program, and their outputs were saved as before-analysis report files.

• The issues reported by the tools were reviewed and recorded in `issues.md`.

• The code was revised to improve naming, documentation, file handling, input handling and the safety of data storage.

• All three tools were run again on the revised program. The after-analysis reports were saved in the Lab5 folder.

4. Issues Identified and Corrections

Issue	Correction applied
Unsafe shell command execution	Removed the shell-command approach instead of invoking a command through the program.
Unsafe pickle deserialization	Replaced pickle-based storage/loading with JSON for task data.
Mutable default argument	Changed the default labels argument to `None` and creates a fresh list inside the function.
Inconsistent task-search return	Made the search function return the matching task ID or `None` when no match is found.
Naming and documentation	Used snake_case names and added module/function docstrings.
File encoding and formatting	Specified UTF-8 for file operations and corrected formatting to follow common Python style conventions.
Task suggestion logic	Replaced random task selection with the first pending task; security-sensitive randomness is not required for this feature.

5. Analysis Results

Tool	Before correction	After correction
Pylint	Score: 5.09/10	Score: 10.00/10
Bandit	Potential security-related findings were reported.	No issues identified in the final scan.
Flake8	Style violations were reported.	No style violations reported by the final scan.

Note: Flake8 normally produces no text when it finds no violations. The saved after-report contains a short confirmation message, and the tool should be rerun directly to verify the clean result.

6. Functional Verification

After the changes, the program was checked for its main operations: adding tasks, marking a task complete, listing pending tasks by priority, searching for a task by keyword, saving and loading tasks in JSON format, and exporting task data. The code also handles a search that has no match by returning `None`.

7. Conclusion

This experiment showed how static analysis tools can help improve the quality and safety of Python code. The issues found in the initial version were documented and corrected, and the revised program received a Pylint score of 10.00/10. The final Bandit scan reported no issues, and the final Flake8 check reported no style violations. The exercise reinforced the importance of readable code, safe data handling, documentation and checking the program after making changes.

8. Files Included

The Lab5 folder contains the revised `todo_manager.py`, the issue log `issues.md`, before-and-after reports for Pylint, Bandit and Flake8, and this written report.